**Alumnos:**

Marco Antonio Aguilar Castillo

Cleber Antonio Bolaños Moreno

Osbaldo Alvarez Martinez

Kevin Ricardo Simon Alfaro

Samuel Jonathan Trujillo Bolaños

**Docente:**

José Miguel Carrera Pacheco

8°B

Proyecto: Conecta-Tehuacán

INVESTIGACION:

S -12. Recuperación de contraseñas accesible y segura

**Recuperación de contraseñas accesible y segura**

**1. ¿Qué es un token de recuperación?**

Un **token de recuperación** es un identificador único, temporal y difícil de predecir que se genera cuando un usuario solicita restablecer su contraseña.

**Características clave:**

- Es **aleatorio y criptográficamente seguro**
- Tiene **uso único (one-time use)**
- Está asociado a:
    - Usuario
    - Tiempo de expiración
- Se envía generalmente por:
    - Correo electrónico
    - SMS (menos recomendado)
    - Enlace seguro (URL)

**Ejemplo:**

https://miapp.com/reset-password?token=abc123XYZ...

**En backend:**

- Se guarda en la base de datos:
    - Token (idealmente **hasheado**)
    - ID de usuario
    - Fecha de expiración

**2. ¿Por qué deben expirar los tokens?**

Los tokens deben expirar para **reducir riesgos de seguridad**.

**Problemas si NO expiran:**

- Un atacante podría usar un token antiguo
- Accesos no autorizados en cualquier momento
- Robo de cuentas

**Buenas prácticas:**

- Expiración corta:
  - 10–15 minutos (ideal)
  - Máximo: 1 hora
- Invalidar token después de uso
- Permitir solo un token activo por usuario

**3. ¿Qué ataques existen en flujos de recuperación?**

Aquí es donde entra lo importante para QA y seguridad:

**1. Enumeración de usuarios**

El sistema revela si un correo existe.

Incorrecto:

"El correo no está registrado"

Correcto:

"Si el correo existe, recibirás instrucciones"

**2. Fuerza bruta de tokens**

Intentar adivinar tokens.

Mitigación:

- Tokens largos (≥ 32 caracteres)
- Uso de UUID o crypto random
- Limitar intentos

**3. Intercepción de token**

Si el token viaja sin seguridad.

Mitigación:

- Usar HTTPS obligatorio
- No incluir datos sensibles en URL

**4. Reutilización de token**

Uso múltiple del mismo token.

Mitigación:

- Invalidarlo tras uso
- Marcar como “consumido”

**5. Ataque de ingeniería social**

Engañar al usuario para usar el token.

Mitigación:

- Mensajes claros:
    - “Si no solicitaste esto, ignora este correo”

**6. Tokens sin expiración o mal gestionados**

Error común en backend.

Mitigación:

- Validar fecha en cada uso
- Limpieza automática de tokens expirados

**4. ¿Cómo se diseña un flujo accesible para recuperación de acceso?**

Aquí mezclas **UX + accesibilidad (a11y)** + QA.

**Flujo accesible ideal**

1. Usuario hace clic en “Olvidé mi contraseña”
2. Ingresa su correo
3. Recibe instrucciones claras
4. Abre enlace
5. Ingresa nueva contraseña
6. Confirma cambio

**Principios de accesibilidad**

**1. Navegación por teclado**

- Todo el flujo debe funcionar con:
    - Tab
    - Enter
- No depender solo del mouse

**2. Compatibilidad con lectores de pantalla**

- Labels claros:

```
<label for="email">Correo electrónico</label>
<input id="email" type="email">
```

- Uso de:
    - aria-live para mensajes dinámicos

**3. Mensajes de error claros**

Ejemplo:

Malo:

Error 401

Bueno:

El enlace ha expirado. Solicita uno nuevo.

**4. Contraste y visibilidad**

- Cumplir WCAG (mínimo contraste 4.5:1)
- Botones visibles y claros

**5. Lenguaje simple**

- Evitar términos técnicos
- Instrucciones paso a paso

**6. Tiempo suficiente**

- Avisar si el enlace expira
- Permitir reenviar fácilmente

**Buenas prácticas técnicas**

- Backend:
    - Tokens hasheados
    - Validación de expiración
    - Rate limiting
- Frontend:
    - Validaciones accesibles
    - Feedback inmediato
- Seguridad:
    - HTTPS
    - No exponer información sensible

**Fuentes (formato APA 7)**


- OWASP. (2021). *Forgot Password Cheat Sheet*. https://cheatsheetseries.owasp.org
- W3C. (2018). *Web Content Accessibility Guidelines (WCAG) 2.1*. https://www.w3.org
- Mozilla Developer Network. (2023). *Web security*. https://developer.mozilla.org
- NIST. (2020). *Digital Identity Guidelines*. https://pages.nist.gov